

Data Privacy & Information Security Policy

Corporate Agentic AI Multi-Agent System Knowledge Base

Document ID:	POL-SEC-002	Version:	4.0
Effective Date:	January 15, 2026	Status:	Active / Approved
Policy Owner:	Chief Information Security Officer & Data Governance Board		

Table of Contents

1. Purpose	8. Access Control
2. Scope	9. Company Device Security
3. Data Classification	10. Confidential Information
4. Personal Data Handling	11. Data Sharing
5. Data Retention	12. Security Incident Reporting
6. Password Requirements	13. Phishing & Suspicious Emails
7. Multi-Factor Authentication	14. Employee Security Responsibilities

1. Purpose

This policy establishes mandatory data protection, information security, and privacy standards to safeguard corporate assets, customer records, and employee information against unauthorized access, disclosure, or breach.

2. Scope

This policy applies to all employees, contractors, third-party vendors, and temporary personnel who access, process, store, or transmit company data or use corporate IT infrastructure.

3. Data Classification

All organizational data must be classified into one of four tiers:

- **Public:** Information approved for public release (e.g., marketing brochures, press releases).
- **Internal:** General operational data for internal use only (e.g., internal phone lists, operational memos).
- **Confidential:** Sensitive business data (e.g., financial forecasts, vendor contracts, source code). Requires encrypted storage.
- **Restricted:** Highly sensitive data (e.g., PII, PHI, credentials, payment card data). Requires strict role-based access and encryption at rest and in transit.

4. Personal Data Handling

Collection and processing of personal data (PII) must adhere to privacy regulations. PII must be collected only for explicit business purposes, anonymized where possible, and protected against unauthorized access.

5. Data Retention

Data must be retained only as long as legally or operationally necessary, after which it must be securely purged.

Data Category	Retention Period	Destruction Method
Customer Transaction & Account Data	7 years post-account closure	Secure cryptographic shredding
Employee Personnel Records	5 years post-employment	Secure shredding / deletion
System Access & Audit Logs	1 year active, 2 years archived	Automated log purging
Temporary Collaboration Files	90 days	Automatic garbage collection

6. Password Requirements

All corporate accounts must use strong, unique passwords adhering to the following rules:

- **Minimum Length:** At least **14 characters**.
- **Complexity:** Must include uppercase letters, lowercase letters, numbers, and special symbols.
- **Reuse Restriction:** Passwords cannot be reused for a minimum of **10 generations** (previous passwords).
- **Rotation:** Standard passwords must be changed every 90 days; privileged administrator accounts every 60 days.

7. Multi-Factor Authentication (MFA)

MFA is mandatory for all employees across every corporate application, VPN connection, email client, and cloud storage portal. Hardware tokens or authenticator apps (e.g., enterprise-approved push authenticators) are required; SMS-based MFA is strictly prohibited due to interception risks.

8. Access Control

Access is granted on a strict **Principle of Least Privilege**. Employees receive access only to systems and directories explicitly required for their job function. Access permissions are audited on a quarterly basis by department managers.

9. Company Device Security

All company-issued laptops and mobile devices must be encrypted using enterprise endpoint protection. Devices must auto-lock after 5 minutes of inactivity and must not be left unattended in public spaces.

10. Confidential Information

Confidential and Restricted data must never be stored on personal cloud storage accounts (e.g., personal Google Drive, Dropbox, iCloud) or unapproved external drives. Only company-vetted cloud repositories are authorized for storing corporate assets.

11. Data Sharing

Sharing confidential or restricted information with external parties requires a signed Non-Disclosure Agreement (NDA) and prior approval from the Legal Department. Data transmissions to external entities must be encrypted.

12. Security Incident Reporting

Any suspected data breach, lost device, or security anomaly must be reported to the IT Security Incident Response Team (SIRT) within **2 hours** of discovery via `security-incident@internal-policy.corp` or the emergency hotline.

13. Phishing & Suspicious Emails

Employees must remain vigilant against social engineering. If an email appears suspicious or unexpected:

- Do not click any links or open attachments.
- Use the integrated **"Report Phish"** button in the corporate email client.
- Notify IT Support immediately if credentials were inadvertently entered.

14. Employee Security Responsibilities

- Never share account credentials, MFA codes, or access badges with anyone.
- Lock workstations whenever leaving the desk.
- Complete mandatory annual cybersecurity awareness training within 30 days of assignment.
- Adhere to all data classification and retention protocols.

Disclaimer: This document is a fictional sample corporate policy created exclusively for an AI portfolio demonstration and RAG system testing project. It does not represent a real company's official policy and is not legally binding.